

Change Management Policy

████ Group — SOX ITGC-oriented working PDF based on the publicly available policy webpage

Source: █████ Group, “Change management policy” — publicly available webpage. Source version reviewed: Version 2.2; last updated 24 July 2026; annual review cycle.

Important: This is a reconstructed/paraphrased PDF for testing, documentation and software-development purposes. It is not an official █████ Group PDF and does not reproduce the source webpage verbatim.

1. Purpose

The policy establishes mandatory requirements for planning, assessing, authorising, testing, implementing and reviewing changes affecting production systems, infrastructure, applications and supporting services. Its objectives include reducing change-related failures, protecting information and service integrity, and maintaining an auditable record of change activity.

2. Scope

The requirements apply to personnel, contractors and third parties who request, approve, implement or review in-scope changes. Covered technology includes application code and configuration, cloud infrastructure and networking, databases and migrations, identity and security configurations, SaaS/third-party integrations, CI/CD and deployment tooling, and managed customer environments where applicable.

3. Key Definitions

A change is an addition, modification or removal that could affect production behaviour or security. Standard changes are pre-authorised, repeatable low-risk activities. Normal changes require assessment and approval. Emergency changes are expedited activities needed to restore service or contain an incident. A CAB or delegated approver authorises applicable changes. Rollback means restoring the last known good state.

4. Policy Requirements

In-scope changes must follow a controlled lifecycle: request, risk assessment, planning, review, testing, approval, implementation, verification and closure. Production implementation requires an approved change record and documented rollback arrangements, except for emergency changes that are subsequently documented and reviewed.

5. Change Categories and Authorisation

Standard changes follow an approved runbook and are periodically reviewed. Normal changes require a change record, risk and impact assessment, peer review, testing evidence and approval before implementation. Higher-risk changes require an independent second reviewer. Emergency changes require contemporaneous approval and a complete retrospective record and review within the specified timeframe.

6. Change Lifecycle

The lifecycle requires the requester to describe the change and affected systems; assess risk, security and dependencies; prepare implementation, testing, rollback and communication plans; obtain appropriate review and approval; test in a non-production environment; implement during an approved window; verify acceptance criteria; and close the record with post-implementation review where required.

7. Environment Separation and Segregation of Duties

Development, staging and production environments are separated with distinct credentials and data controls. Production data should not be copied to lower environments unless appropriately masked or synthesised. The policy requires controls preventing developers from independently deploying to production, independent review of production database changes, and separation between change authorship and approval. Privileged deployment credentials are controlled and auditable.

8. Testing and Quality Gates

The policy requires automated development and security checks appropriate to the technology, with test evidence linked to the change record. Database and data migrations should be tested against representative data and designed to be reversible or correctable. Material customer-impacting changes should be validated in a production-like staging environment. Feature flags may be used to separate deployment from release and facilitate controlled rollout.

9. Emergency Change

Emergency changes are limited to service restoration or active security incidents. The implementation should be logged as far as practicable, with a complete change record documenting the cause, action and validation produced within the required retrospective period and reviewed by the CAB. Changes involving security controls, access or customer data receive additional security review.

10. Change Freeze and Communication

Change freezes may be introduced during periods of elevated risk or reduced staffing. During a freeze, only qualifying emergency changes are permitted. Material customer-impacting changes should be communicated in advance using agreed channels and scheduled to minimise disruption.

11. Documentation, Evidence and Records

Each change record should contain the change description, risk assessment, approval, test evidence and rollback plan. Records are retained for the stated minimum period or longer where contractual or legal requirements apply. Approvals should provide an auditable trail. Failed and emergency changes require documented post-implementation review. Records may be made available to auditors and, where contractually appropriate, customers.

12. Framework Alignment

The source policy identifies alignment with SOC 2 Trust Services Criteria CC8.1, ISO/IEC 27001:2022 Annex A controls 8.31 and 8.32, NIST SP 800-53 Rev. 5 Configuration Management controls including CM-3, CM-4 and CM-5, SOX IT general controls for change management and segregation of duties, and ITIL 4 change enablement.

13. Roles and Responsibilities

The change requester prepares a complete record, risk assessment, test plan and rollback plan. The approver/CAB assesses readiness and authorises or rejects changes. The implementer executes the approved procedure, stops or rolls back when required, and records outcomes. The CISO owns the policy, reviews security-impacting and emergency changes, and reports change metrics.

14. Exceptions

Exceptions require documented approval by the CISO or delegate, business justification, risk assessment, compensating controls and an expiry date. Exceptions are logged and reviewed periodically.

15. Enforcement

Production deployment outside the required process is treated as a serious policy breach. Consequences can include removal of deployment privileges, disciplinary action and contractual remedies for third parties, with repeated unauthorised activity escalated to leadership.

16. Review

The policy is reviewed at least annually and after significant incidents, technology changes or changes in certification scope. Version history is maintained in the compliance repository.

SOX ITGC Control Mapping — Useful for Your Python Application

Control ID	SOX ITGC Area	Control Theme	Potential Evidence
CM-01	Change Management	Changes are formally requested and risk assessed	Change ticket; risk assessment
CM-02	Change Management	Changes are tested before production	Test/UAT evidence; test results
CM-03	Change Management	Production changes require appropriate approval	Approval record; CAB approval

Control ID	SOX ITGC Area	Control Theme	Potential Evidence
CM-04	Change Management	Rollback procedures are documented	Rollback plan; implementation plan
CM-05	Segregation of Duties	Change author cannot solely approve own production change	Workflow; approval matrix
CM-06	Environment Management	Development, test and production are separated	Environment architecture; access listing
CM-07	Privileged Access	Production deployment privileges are restricted	Privileged access listing
CM-08	Emergency Changes	Emergency changes receive retrospective review	Emergency ticket; CAB review
CM-09	Change Evidence	Test and approval evidence is retained with change record	Ticket attachments/audit trail
CM-10	Post-Implementation	Failed/emergency changes receive post-implementation review	Incident report; remediation evidence

Source note: The control mapping above is an analytical mapping created for application testing; it is not represented as an official [REDACTED] Group RCM. The source webpage explicitly references SOX IT general controls for change management and segregation of duties.

Source URL: [https://\[REDACTED\]group.org/legal/policies/change-mgmt](https://[REDACTED]group.org/legal/policies/change-mgmt)